2026 국가암호기술 인력양성과정 (12기)

암호통신 네트워크 설계 및 분석

SPA · QUIC 기반 서버-클라이언트 통신

이름 이지은

소속 한국과학기술원

제출일 2026년 10월 13일

목차

1 프로그램 동작 **2**
1.1 목표 및 시나리오 . . . 2
1.1.1 SPA · QUIC 구현 . . . 2
1.1.2 시나리오 . . . 2
1.2 프로그램 화면 및 실행 . . . 2
1.3 통신 실습 및 CLI . . . 3
1.4 위성영상 서비스 . . . 3
1.5 미등록 사용자 및 권한 종료 . . . 4
1.6 통신 설정 . . . 4

2 SPA · QUIC 통신 알고리즘 **5**
2.1 SPA 인증 패킷 1개 전송 . . . 5
2.1.1 인증 정보 구성 . . . 5
2.1.2 요청 보호 및 전송 . . . 5
2.2 인증 검증 . . . 5
2.2.1 인증 요청 유효성 검사 . . . 6
2.2.2 재전송 차단 . . . 6
2.3 방화벽이 일시적으로 QUIC 접근 허용 . . . 6
2.3.1 접근 권한 생성 . . . 6
2.3.2 패킷별 접근 검사 및 차단 . . . 6
2.4 QUIC 연결 시작 및 데이터 통신 . . . 6
2.4.1 QUIC 보안 연결 수립 . . . 7
2.4.2 메시지 송수신: Echo 기능 . . . 7
2.4.3 파일 데이터 전송: 영상 확인 기능 . . . 7

3 패킷 캡처 및 통신 검증 **7**

4 AI 활용 **7**

1 프로그램 동작

1.1 목표 및 시나리오

1.1.1 SPA · QUIC 구현

본 프로그램 목표는 SPA 인증 전후의 접근제어와 실제 QUIC 통신을 하나의 서버-클라이언트 프로그램으로 검증하는 것이다. 클라이언트는 암호학적 증명이 담긴 인증 요청을 UDP 데이터그램 하나로 전송한다. 서버는 등록 정보 · 서명 · 시간 · Nonce를 검증하여 접근 권한을 부여하며, 승인되지 않은 접속은 UDP 게이트에서 폐기한다. 승인된 접속에는 QUIC/TLS 1.3과 응용 인증을 적용하고, 메시지 송수신과 PCAP으로 동작을 확인한다.

1.1.2 시나리오

접근 권한 인증을 통해 제공될 서비스는 항공우주 분야에 대한 관심을 바탕으로 인가된 지상국 운영자가 위성 관측자료 제공 서버에 접속하는 상황을 설정했다. 위성의 광학 탑재체가 획득한 관측자료는 지상시스템(Ground Segment)에서의 접근 통제와 데이터 전송 보안이 중요하다. 또한 위성 시스템은 전력과 통신 대역폭 등 운용 자원이 제한되며, 지상구간에서도 불필요한 접속 요청을 줄이고 인가된 운영자에게 관측자료를 안전하게 제공할 필요가 있다. 이에 SPA의 단일 패킷 사전 인증과 비인가 패킷 무응답 차단 방식을 적용하여 승인된 단말에만 서비스 접근을 허용하고, QUIC/TLS 1.3을 통해 관측자료를 암호화하여 전송하도록 구성하였다. 응용 서비스에는 NASA GIBS의 VIIRS 지구관측 영상을 활용하여 인증부터 위성영상 요청 · 수신까지의 보안 통신 과정을 구현하였다.

1.2 프로그램 화면 및 실행

프로그램은 서버 실행 · 중지, PCAP 기록, 클라이언트 선택 등의 기능을 제공하며 각 통신 단계의 상태와 서버 · 클라이언트 처리 결과를 화면에서 확인할 수 있다.

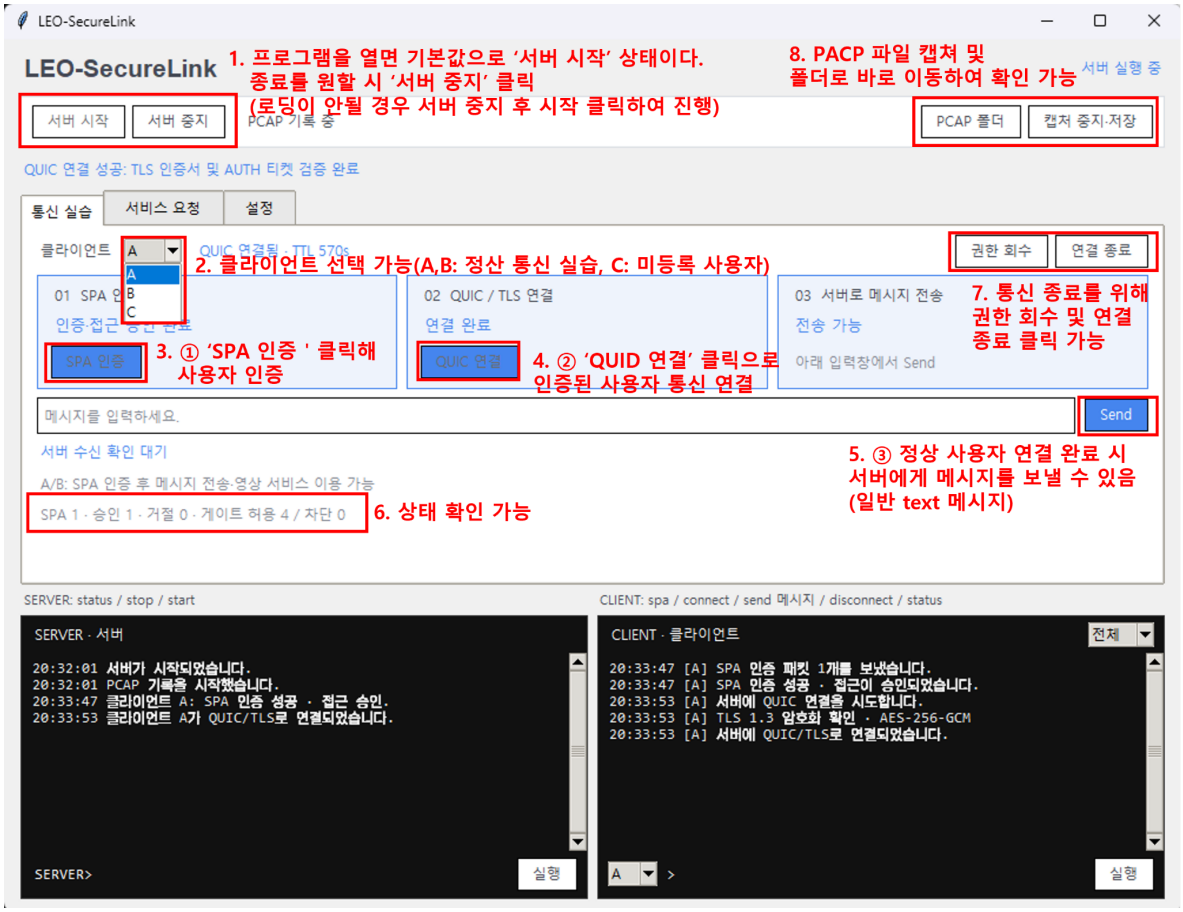


Figure 1: 메인 화면

1.3 통신 실습 및 CLI

통신 실습 탭에서는 A · B의 SPA 인증, QUIC 연결, 메시지 전송을 순서대로 실행하며 하단 CLI에서도 같은 명령을 입력하고 서버의 수신 결과를 확인할 수 있다.

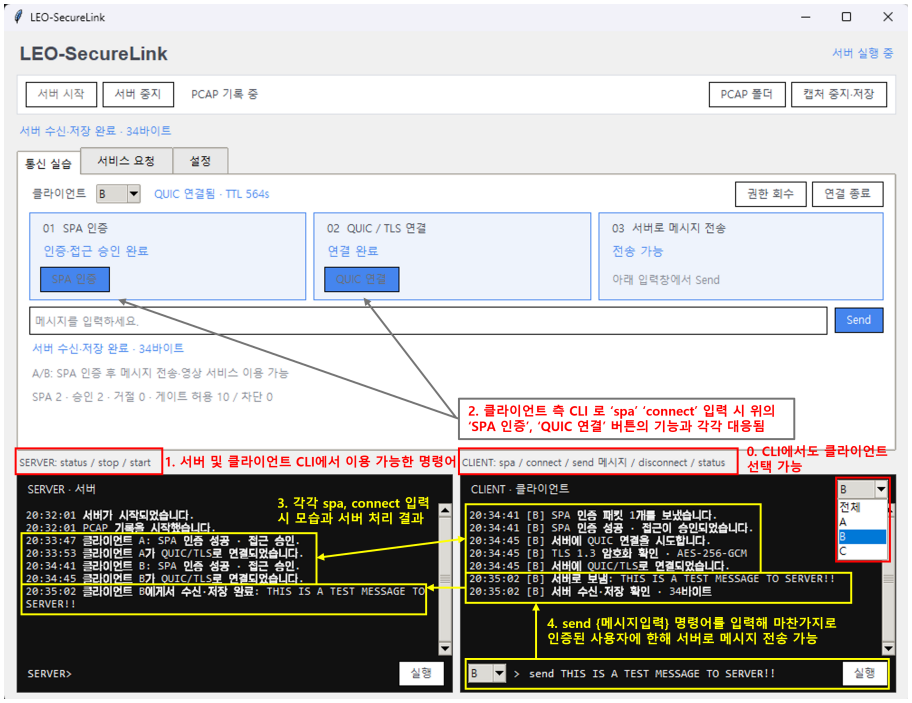


Figure 2: 통신 실습 탭과 서버 · 클라이언트 CLI

1.4 위성영상 서비스

서비스 요청 탭에서는 인증된 사용자가 관측 날짜를 선택해 NASA 위성영상을 요청하고, QUIC으로 수신한 이미지와 전송 진행 상태를 확인할 수 있다.

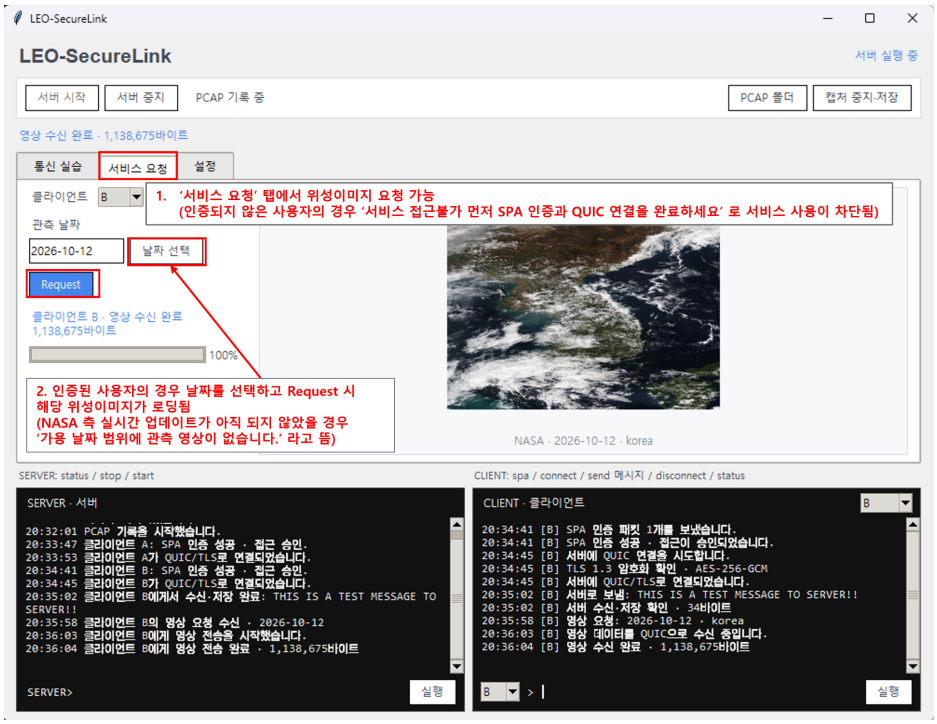


Figure 3: 위성영상 요청 및 수신 결과

1.5 미등록 사용자 및 권한 종료

미등록 사용자 C의 인증 실패와 정상 사용자 A · B의 권한 만료 · 회수 결과는 통신 상태와 서버 로그에서 확인할 수 있다.

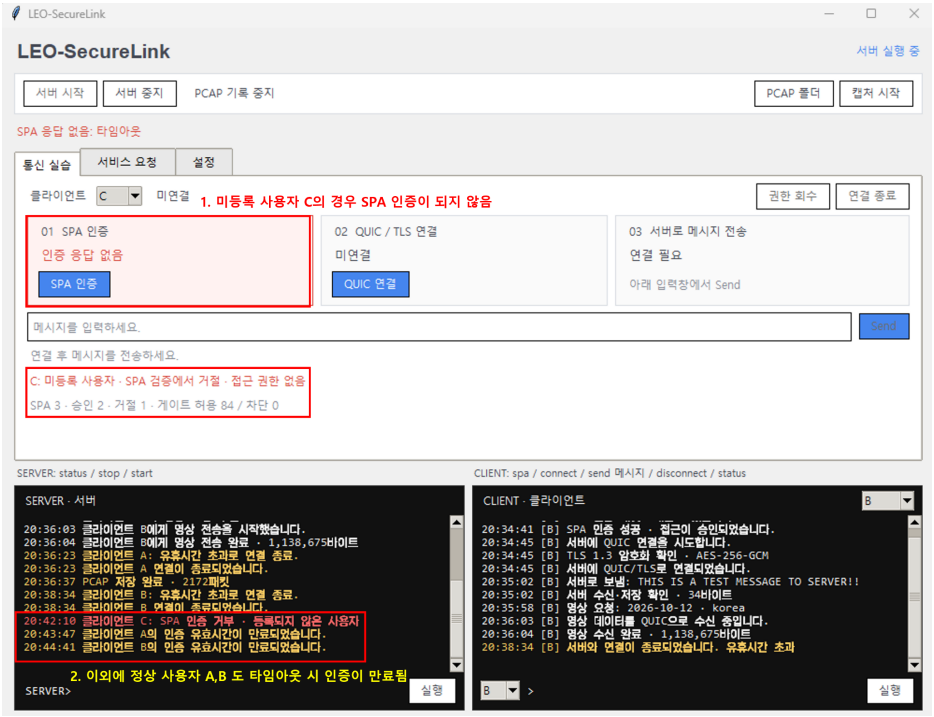


Figure 4: 미등록 사용자 차단과 권한 종료 기록

1.6 통신 설정

설정 탭에서는 SPA 접근 권한 시간과 QUIC 유휴시간을 변경하고, 서버 재시작 후 설정이 적용된다.

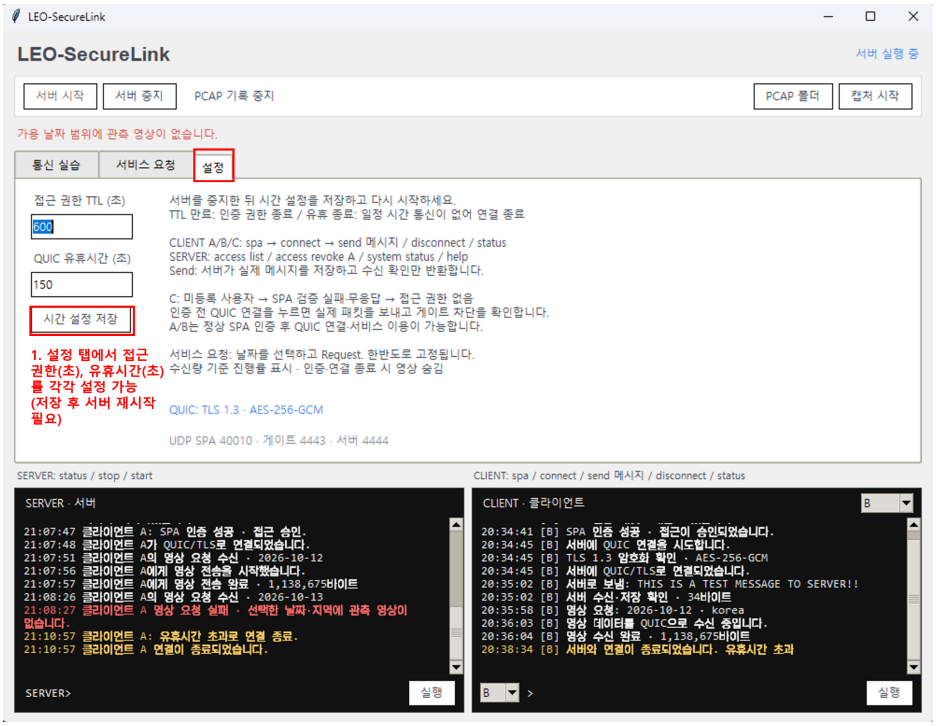


Figure 5: 접근 권한 및 유휴시간 설정

2 SPA · QUIC 통신 알고리즘

본 장에서는 강의자료의 네 단계 통신 절차를 실제 프로그램에서 어떻게 구현했는지 설명한다. (1) 클라이언트는 등록된 인증키로 요청 정보를 서명 · 암호화하여 SPA 인증 패킷 하나를 전송한다. (2) SPA 검증 모듈은 등록 사용자, 암호문 무결성, 서명, 요청 시각과 논스를 확인하고 정상 요청에만 성공 응답을 반환한다. (3) 인증 결과를 접근 권한 저장소에 기록하면 UDP 게이트가 해당 클라이언트의 패킷을 일정 시간 내부 QUIC 서버로 전달한다. (4) 승인된 클라이언트는 QUIC/TLS 1.3 연결과 서비스 티켓 인증을 마친 뒤 메시지와 위성영상 데이터를 안전하게 송수신한다.

단계	통신 절차	구현 코드
①	SPA 인증 패킷 1개 전송	`crypto.py`, `spa_client.py`
②	인증 검증	`spa_server.py`, `credentials.py`
③	방화벽이 일시적으로 QUIC 접근 허용	`auth_store.py`, `udp_gateway.py`
④	QUIC 연결 시작 및 데이터 통신	`quic_client.py`, `quic_server.py`

2.1 SPA 인증 패킷 1개 전송

첫 단계에서는 클라이언트가 자신의 인증 정보를 하나의 UDP 데이터그램에 담아 SPA 서버로 보낸다. 요청 내용은 Ed25519로 서명한 뒤 AES-256-GCM으로 암호화하며, 패킷을 나누거나 자동 재전송하지 않는다. 따라서 서버는 QUIC 연결을 시작하기 전에 클라이언트의 인증 요청을 받을 수 있다.

2.1.1 인증 정보 구성

`credentials.py`는 정상 사용자 A · B별로 32바이트 사전 공유 키(PSK)와 Ed25519 서명키 쌍을 준비한다. 클라이언트는 자신의 PSK와 개인 서명키를 보유하고, 서버는 사용자별 PSK와 공개 검증키를 등록한다. PSK는 SPA 요청 암호화에, Ed25519 키는 요청자 서명 생성 · 검증에 사용한다. 미등록 사용자 C는 서버의 허용 사용자 목록에 포함하지 않는다.

SPA 요청의 주요 필드는 버전 `v`, 사용자 `client_id`, 밀리초 단위 `timestamp_ms`, 무작위 `request_nonce`, 서비스 식별자 `requested_service`이다. 논스는 무작위 16바이트를 32자리 16진 문자열로 표현한다. 이 값들은 인증 요청의 유효성 검사와 재전송 탐지에 사용된다.

2.1.2 요청 보호 및 전송

`crypto.py`는 인증 요청의 주요 필드를 정렬된 UTF-8 JSON으로 직렬화한 뒤 Ed25519 개인키로 서명한다. 이후 서명값을 포함한 요청 전체를 AES-256-GCM으로 암호화하며, 매 요청마다 새로운 12바이트 초기화 벡터(IV)를 생성한다. AES-GCM은 인증정보의 기밀성과 무결성을 보호하고, Ed25519 서명은 등록된 사용자에 의해 생성된 요청인지 검증하는 데 사용된다.

추가 인증 데이터(AAD)에는 버전, 사용자 ID, 요청 · 응답 방향 정보를 포함한다. 이를 통해 암호문 외부 필드의 변조와 요청 · 응답 간 혼동을 검출한다. 최종 SPA 패킷은 다음과 같은 JSON 형식으로 구성된다.

```
{"v":1,"client_id":"A","iv_b64":"...","ciphertext_b64":"..."}
```

`SpaClient.request`는 암호화된 인증 요청을 UDP 소켓의 `sendto` 호출 한 번으로 전송한다. 요청 크기는 최대 1,200바이트로 제한하며 패킷 분할이나 자동 재전송은 수행하지 않는다. 응답 대기 후 SPA 소켓을 정리하고, 이후 QUIC 연결에서 동일한 클라이언트 출발지 포트를 사용하여 서버에 등록된 접근 권한과 실제 접속 주체를 일치시킨다.

2.2 인증 검증

두 번째 단계에서는 SPA 서버가 수신한 인증 패킷을 복호화하고 등록 사용자 여부와 서명의 유효성을 확인한다. 요청 시각과 논스를 함께 검사하여 오래된 요청이나 동일 인증 패킷의 재사용을 차단한다. 이때 모든 조건을 만족한 경우에만 암호화된 성공 응답을 보내고, 실패한 요청에는 네트워크 응답을 보내지 않는다.

2.2.1 인증 요청 유효성 검사

spa_server.py의 datagram_received는 수신 패킷을 crypto.py 검증 함수로 전달한다. 서버는 외부 JSON 구조와 등록 사용자 정보, AES-GCM 인증 태그, 복호화된 필드의 사용자 일치 여부, Ed25519 서명, 요청 시각과 논스를 순서대로 확인하도록 하였다. 또한 서명과 암호문이 올바르더라도 서버 시각과 요청 시각의 차이가 기본 30초를 초과하면 인증을 거부한다.

2.2.2 재전송 차단

해당 통신 프로토콜의 경우 재전송 공격 등의 문제에도 대비해야 하므로 AuthStore는 인증에 성공한 요청의 사용자 ID와 논스를 기록한다. 같은 사용자가 동일한 논스를 다시 보내면 재전송된 요청으로 판단한다. 기본 저장 시간은 70초이며, 원래 요청 시각도 30초 허용 범위를 벗어나면 재사용할 수 없도록 검증한다. 검증에 성공하면 서버는 요청 논스, 사용자 ID, QUIC 게이트 주소 · 포트, 승인 만료 시각 및 일회용 서비스 티켓을 포함하는 성공 응답을 암호화해 반환한다. 클라이언트는 응답의 사용자와 논스가 자신이 보낸 요청과 일치하는지 검사한다. 잘못된 서명이나 만료, 미등록 등 비정상 요청에는 실패 응답을 보내지 않으므로 클라이언트에는 응답 시간 초과가 뜬다.

2.3 방화벽이 일시적으로 QUIC 접근 허용

세 번째 단계에서는 SPA 인증 결과를 실제 패킷 전달 규칙에 반영한다. 본 프로그램은 Windows 방화벽 설정을 변경하는 대신 udp_gateway.py의 UdpGateway로 사용자 공간 UDP 접근 제어 게이트를 직접 구현하였다. 게이트는 기본적으로 서비스 접근을 차단하고, SPA 인증으로 등록된 출발지에 한해 제한된 시간 동안 QUIC 데이터그램을 전달한다.

2.3.1 접근 권한 생성

auth_store.py의 AuthStore.authorize는 SPA 검증을 통과한 사용자에게 접근 권한을 생성한다. 승인 정보에는 사용자 ID, 출발지 IP · UDP 포트, 만료 시각, 단조 시계 기반 종료 시점, 서비스 티켓 해시, 티켓 사용 여부, 권한 세대 식별자(generation)를 저장한다. 이때 허용 대상은 IP 주소뿐 아니라 출발지 IP와 UDP 포트의 조합을 사용한다. 따라서 같은 PC에서 실행되어 IP가 동일하더라도 A의 인증이 다른 포트를 사용하는 B나 C의 접근까지 허용하지 않는다. 또한 동일한 출발지에 다른 사용자의 권한이 이미 등록되어 있으면 새 승인을 거부하여 권한 충돌을 방지하도록 하였다.

이후 서버는 secrets.token_hex(32)로 무작위 32바이트를 64자리 16진수로 표현한 서비스 티켓을 발급하고, 저장소에는 티켓의 SHA-256 해시를 보관한다. QUIC 연결 후에는 consume_ticket에서 티켓 해시를 hmac.compare_digest로 비교하고 한 번만 사용하도록 처리한다.

2.3.2 패킷별 접근 검사 및 차단

udp_gateway.py의 UdpGateway.datagram_received는 수신 데이터그램의 출발지 IP · UDP 포트를 확인하고 AuthStore.allowed로 유효한 접근 권한을 조회한다. 기본 정책은 차단이며 일치하는 권한이 없거나 명시적 차단 목록인 blocked_endpoints에 포함된 경우 패킷을 응답 없이 폐기한다. 따라서 SPA 인증에 실패한 C의 QUIC Initial은 게이트에서 관측되더라도 내부 QUIC 서버로 전달되지 않는다.

승인된 출발지에는 create_mapping이 전용 UDP 중계 소켓을 생성하고, 출발지와 중계 소켓, 권한 세대 식별자를 매핑하여 후속 패킷을 전달한다. 소켓 생성 직후에도 권한을 다시 확인하며, 기존 매핑의 세대가 현재 승인과 다르면 이전 소켓을 닫고 새 매핑을 생성한다. 내부 서버의 응답 역시 Upstream.datagram_received에서 권한과 차단 여부, 세대 일치를 확인한 뒤 클라이언트로 반환한다. 이 과정에서 게이트는 QUIC 암호문을 복호화하지 않고 UDP 페이로드를 그대로 중계한다.

2.4 QUIC 연결 시작 및 데이터 통신

네 번째 단계에서는 접근 허가를 받은 클라이언트가 실제 QUIC/TLS 1.3 연결을 생성한다. 연결 이후 일회용 서비스 티켓을 추가 검증한 다음 메시지와 위성영상 자료를 같은 보호된 통신 경로로 전송한다.

2.4.1 QUIC 보안 연결 수립

quic_client.py와 quic_server.py는 aioquic으로 실제 QUIC 연결을 구현한다. 클라이언트는 게이트에 접속하고 게이트는 승인된 패킷을 내부 QUIC 서버로 전달한다. TLS 1.3 핸드셰이크에서 서버 인증서를 검증하며 응용 프로토콜 식별자(ALPN) spa-quic-demo/1을 협상한다. QUIC 서버는 P-256 기반 실습용 인증서를 사용하고 클라이언트는 이를 명시적으로 신뢰하도록 설정한다.

TLS 연결이 완료되면 클라이언트는 QUIC 스트림의 AUTH 요청에 사용자 ID와 일회용 티켓을 넣어 전송한다. 서버는 consume_ticket와 현재 승인 정보를 확인한 뒤 AUTH_OK를 반환하고 애플리케이션 요청 처리를 시작한다. 서버 인증서 검증과 클라이언트의 서비스 티켓 검증은 각각 다른 목적의 인증 단계이다.

2.4.2 메시지 송수신: Echo 기능

서버와 클라이언트는 하나의 양방향 QUIC 스트림에서 메시지를 주고받는다. 클라이언트가 MESSAGE_SUBMIT으로 요청 ID와 메시지를 보내면 서버는 MESSAGE_ACK를 반환한다. 클라이언트는 요청 ID가 일치하는 확인 응답을 받아 성공을 표시한다. 기존 Echo 요청도 연결 확인용으로 제공하므로 한 번 인증된 연결에서 여러 메시지의 실제 왕복을 확인할 수 있다.

2.4.3 파일 데이터 전송: 영상 확인 기능

위성영상은 QUIC 데이터 송수신을 실제 파일 전송에 적용한 응용 기능이다. imagery/nasa_gibs.py는 NASA GIBS의 공식 HTTPS API로 한반도 광학 관측자료를 받아 서버 캐시에 저장한다. 외부 HTTPS 수집 이후 서버가 직접 이미지 바이트를 QUIC 연결로 송신하므로 브라우저의 외부 이미지 링크 표시와는 구분된다.

영상 요청은 IMAGE_GET으로 시작하고 서버는 IMAGE_META, 실제 바이너리 데이터, IMAGE_END 순서로 응답한다. 클라이언트는 지정된 길이만큼 데이터를 수신하면서 SHA-256을 계산하고, 크기 · 해시 · 영상 형식을 검증한 뒤 IMAGE_ACK를 전송한다. 전송 단위인 32KiB는 응용 프로그램 내부의 처리 크기이며 UDP 데이터그램 크기를 뜻하지 않는다. 이 과정으로 인증된 QUIC 연결에서 실제 위성 관측자료가 전송되었는지를 확인한다.

3 패킷 캡처 및 통신 검증

본 프로그램의 SPA 인증과 QUIC 데이터 전송이 실제 네트워크에서 이루어졌는지 확인하기 위해 Wireshark로 PCAP 파일을 분석하였다. '패킷결과' 폴더의 demo_20261013_220619_164962.pcap에는 약 43초 동안 총 2,173개의 패킷이 기록되었다.

먼저 SPA 서버의 UDP 40010번 포트에서는 정상 사용자 A와 B의 인증 요청이 각각 1개씩 관측되었으며, 서버는 각 요청에 대해 성공 응답을 반환하였다. 미등록 사용자 C의 인증 요청도 1개 관측되었으나, 이에 대한 서버 응답은 나타나지 않았다. 이는 인증에 실패한 요청에 응답하지 않도록 구현한 SPA 서버의 동작과 일치한다.

SPA 인증 이후 A의 UDP 55201번 포트에서 QUIC 게이트의 4443번 포트로 연결 요청이 전송되었다. 이후 게이트는 내부 QUIC 서버의 4444번 포트로 데이터그램을 중계하였다.

패킷 분석 결과, 클라이언트에서 게이트로 전송된 86개 데이터그램이 내부 서버에도 전달되었으며, 내부 서버에서 반환한 998개 데이터그램도 게이트를 거쳐 클라이언트에 전달되었다. 중계 전후의 UDP 페이로드가 일치하는 것을 확인하여, 실제 QUIC 통신이 게이트를 통해 이루어졌음을 검증하였다.

또한 QUIC Initial 패킷과 이후의 암호화된 데이터 패킷이 관측되었다. 이를 통해 SPA 인증 이후 QUIC 연결과 데이터 송수신이 수행되었음을 확인하였다. 다만 이번 캡처에서 미등록 사용자 C의 QUIC 연결 시도는 관측되지 않았으므로 게이트의 미인증 QUIC 패킷 차단은 별도 시험 결과로 확인해야 한다.

4 AI 활용

활용 AI: ChatGPT, Codex (GPT-6.1 Sol)

우선 만들어야 할 통신 결과물의 구성 및 방법을 이해하는 데 AI를 활용함. 이후 원하는 결과물 형태 및 전체 구성에 대한 아이디어를 전달한 후 Codex를 통해 프로그램 제작에 도움을 받음. 이후 세부 지침을 주며 원하는 수정 방향을 제시함. 마지막으로 보고서 작성 시에는 원하는 방향 및 내용을 제시해서 검수된 내용을 바탕으로 출력한 LaTeX에 기반하여 직접 문장들을 수정하며 마무리함.